



Actividad | #3 |

Plan de Acción

Seguridad Informática I

Ingeniería en Desarrollo de Software



academi**ag**lobal

TUTOR: Sin Tutor

ALUMNO: Oscar Esteban Sánchez Leyva

FECHA: 26/Agosto/2026

ÍNDICE

ÍNDICE	2
INTRODUCCIÓN	3
DESCRIPCIÓN	4
JUSTIFICACIÓN	5
DESARROLLO	6
SELECCIÓN DE SOFTWARE.....	6
PLAN DE ACCIÓN - CRONOGRAMA	8
PRÁCTICA DE PLAN DE ACCIÓN	9
CAPTURA 1	9
CAPTURA 2.....	10
CAPTURA 3.....	11
EVALUACIÓN	12
CONCLUSIÓN.....	14
REFERENCIAS.....	15

INTRODUCCIÓN

En el presente documento se hablará del proyecto final, en el que se consolidan los esfuerzos realizados en las Actividades 1 y 2 de la materia Seguridad Informática I. En la primera actividad, se identificaron las principales vulnerabilidades y amenazas de una institución educativa en Veracruz, cercana a la costa, con dos pisos, 18 aulas, departamentos administrativos, un centro de cómputo, una biblioteca y múltiples equipos, incluidos dos servidores conectados tanto de forma alámbrica como inalámbrica. Entre las vulnerabilidades más preocupantes se destacan el uso de credenciales débiles como "Equipo1" y "1234abc", un firewall deshabilitado, el uso de un antivirus gratuito NOD32, acceso sin restricciones a Internet para uso personal y la presencia de software de origen desconocido en el servidor secundario.

En la segunda actividad, se examinaron las fuentes de ataque que podrían explotar estas debilidades, incluyendo ingeniería social y phishing, ransomware tipo LockBit, inyección SQL, suplantación ARP/DNS, ataques de denegación de servicio (DoS) y el robo físico de equipos sin cifrar. Ahora, en esta tercera etapa, el objetivo es desarrollar un Plan de Acción concreto y viable que se alinee con el marco NIST y la norma ISO 27001. Este plan busca implementar recomendaciones de mitigación empleando herramientas de seguridad reales. Se especificarán soluciones para firewall, protección de endpoints, gestión de identidades, cifrado y copias de seguridad 3-2-1, asegurando así la confidencialidad, integridad y disponibilidad de la información institucional.

DESCRIPCIÓN

El escenario de la actividad describe una institución educativa con una infraestructura tecnológica diversa y falta de controles formales de seguridad. El servidor principal alberga la base de datos general, mientras que el servidor secundario funciona con un sistema descargado de Internet sin ser verificado, lo que presenta un riesgo de entrada no autorizada y de código malicioso. Los ordenadores de la planta baja se conectan directamente al módem, sin pasar por ningún firewall o router estructurado. Además, la conexión Wi-Fi carece del cifrado moderno WPA3 y de contraseñas seguras, y no existe segmentación de la red mediante VLANs. Los dispositivos han experimentado lentitud y falta de espacio en el último mes, lo que sugiere una falta de políticas para la gestión de almacenamiento y copias de seguridad.

La tarea en esta Actividad 3 es convertir el diagnóstico en acciones concretas: seleccionar herramientas que satisfagan las funciones necesarias, desarrollar un cronograma que detalle qué se hará, cuándo y con qué recursos, implementar al menos una herramienta con documentación en capturas y evaluar cómo esta herramienta resuelve la mayoría de los problemas identificados. El plan debe abordar las cinco categorías detectadas: amenazas humanas, lógicas, físicas, vulnerabilidades de almacenamiento y de comunicación. La entrega debe seguir el formato APA, con portada oficial, referencias y evidencias prácticas, y se aconseja añadir el documento al portafolio de GitHub del alumno para mejorar su trazabilidad profesional.

JUSTIFICACIÓN

La implementación de un plan de acción meticulosamente estructurado es imperativa debido a que las vulnerabilidades identificadas no se presentan de manera aislada, sino que constituyen una serie interconectada de explotaciones potenciales. Una contraseña débil, combinada con un firewall deshabilitado y un sistema de navegación sin filtrado adecuado, permite que un ataque de phishing instale un keylogger, capture credenciales y se desplace lateralmente hacia el servidor principal.

En ausencia de segmentación, autenticación multifactor (MFA) y respaldos inmutables, un incidente de ransomware podría comprometer toda la operación académica, resultando en la pérdida irreversible de datos personales de estudiantes y docentes y el incumplimiento de la Ley Federal de Protección de Datos Personales. La implementación de soluciones como pfSense, actuando como un firewall perimetral de código abierto con IDS/IPS Suricata, junto con herramientas como Malwarebytes Nebula o Bitdefender GravityZone como EDR, el uso de Microsoft Active Directory con políticas de contraseñas robustas y autenticación multifactorial, BitLocker para el cifrado de datos y Veeam Backup para la estrategia de respaldo 3-2-1, facilita la aplicación del principio de defensa en profundidad mientras se mantienen los costos controlados para una institución educativa.

Estas herramientas han sido examinadas en los materiales de apoyo del curso (U3 Configuración del Router y U4 Malwarebytes como Sistema de Detección) y cuentan con una sólida documentación, soporte comunitario y cumplen con estándares reconocidos internacionalmente. La adopción de estas medidas no solo mitiga las 16 incidencias documentadas, sino que establece una postura defensiva proactiva, auditable y escalable, alineada con las mejores prácticas internacionales.

DESARROLLO

SELECCIÓN DE SOFTWARE

La tabla a continuación describe seis herramientas de ciberseguridad, detallando los problemas que resuelven y sus propósitos:

- **pfSense y Suricata:** Ofrecen protección a la red mediante firewall, VLAN, NAT e IDS/IPS, ayudando a prevenir ataques desde Internet, accesos no autorizados y problemas con redes Wi-Fi.
- **Malwarebytes y Bitdefender:** Protegen los dispositivos contra virus y malware, detectando amenazas en tiempo real, ransomware y programas potencialmente peligrosos.
- **Active Directory, GPO y MFA:** Gestionan usuarios, contraseñas y permisos, permitiendo implementar políticas de seguridad, bloquear el uso de puertos USB y exigir autenticación multifactor.
- **BitLocker y VeraCrypt:** Cifran los discos duros de las computadoras para asegurar que, en caso de pérdida o robo del equipo, los datos no sean fácilmente accesibles.
- **Veeam Backup, NAS y Wasabi:** Hacen copias de seguridad de los datos, facilitando su recuperación ante situaciones como ransomware, fallos, pérdidas o daños en los archivos.
- **Ubiquiti UniFi junto con WPA3-Enterprise:** Refuerzan la seguridad de la red Wi-Fi mediante el uso de WPA3, autenticación RADIUS, VLAN y control de acceso.

La estrategia busca proteger la empresa en varios niveles: **red, equipos, usuarios, información, respaldos y Wi-Fi**. Esto reduce los riesgos de malware, robos de información, accesos no autorizados y pérdida de datos.

Herramienta	Vulnerabilidad y proceso a realizar	Funcionalidad / Justificacion	URL
1. pfSense 2.7.2 Community + Suricata IDS/IPS	Firewall deshabilitado, Equipos conectados directo al modem, Falta de segmentacion, Ataques de Internet, Wi-Fi inseguro	Firewall perimetral, NAT, VLANs (10 Admin, 20 Alumnos, 30 Servidores), bloqueo por defecto, prevencion DoS, DNS spoofing, ARP spoofing. Reemplaza conexion directa al modem por red estructurada router/firewall/switch.	https://www.pfsense.org/
2. Malwarebytes Nebula / Bitdefender GravityZone Business	Malware/virus, Software de procedencia desconocida, Uso sin restricciones de Internet, Antivirus gratuito NOD32	EDR con proteccion en tiempo real, anti-ransomware, anti-exploit, escaneo de descargas, bloqueo de sitios maliciosos. Permite cuarentenar software desconocido del Servidor2 y reemplazar NOD32 free.	https://www.malwarebytes.com/business/nebula
3. Microsoft Active Directory + GPO + MFA (Microsoft Authenticator)	Acceso no autorizado, Contraseñas debiles (Equipo1/1234abc), Uso inadecuado de equipos, Ingenieria social, Instalacion software no autorizado	Gestion centralizada de identidades, politica de contraseñas de 12 caracteres complejos, rotacion 90 dias, MFA obligatorio, bloqueo instalacion por usuarios estandar, GPO para bloqueo USB y filtro web.	https://learn.microsoft.com/entra/
4. BitLocker + VeraCrypt	Robo de equipos, Dano accidental, Perdida/corrupcion de informacion	Cifrado de disco completo AES-256. Si roban laptop, datos ilegibles sin clave escrow en AD. Mitiga data breach.	https://learn.microsoft.com/bitlocker
5. Veeam Backup Community + NAS Synology + Wasabi Immutable	Poco espacio disponible, Falta de respaldos suficientes, Concentracion de info en servidores, Perdida/corrupcion de info	Estrategia 3-2-1: 3 copias, 2 medios (NAS local + Wasabi), 1 offsite inmutable. Respaldo diario incremental + full semanal. Recupera ante ransomware, incendio, sismo.	https://www.veeam.com/
6. Ubiquiti UniFi + WPA3-Enterprise	Uso de Wi-Fi, Uso sin restricciones de Internet	Wi-Fi WPA3, RADIUS integrado con AD, SSID por VLAN, filtrado de contenido, control de acceso.	https://ui.com/

PLAN DE ACCIÓN - CRONOGRAMA

Este es un plan de mejora de seguridad informática que se desarrollará en 4 semanas, donde cada semana se enfocará en un tipo de riesgo distinto:

- Durante la primera semana, se protegerán las cuentas implementando contraseñas seguras, autenticación multifactor (MFA) y capacitación para prevenir el phishing.
- En la segunda semana, se fortalecerá la red mediante la instalación de un firewall, la segmentación con VLAN y la mejora de la seguridad del Wi-Fi.
- La tercera semana estará dedicada a la revisión de equipos para detectar y eliminar malware y programas no autorizados, además de controlar el uso de dispositivos USB.
- Finalmente, en la cuarta semana, se protegerán los datos estableciendo respaldos con Veeam, utilizando almacenamiento adicional, cifrando laptops y aplicando medidas de seguridad física.

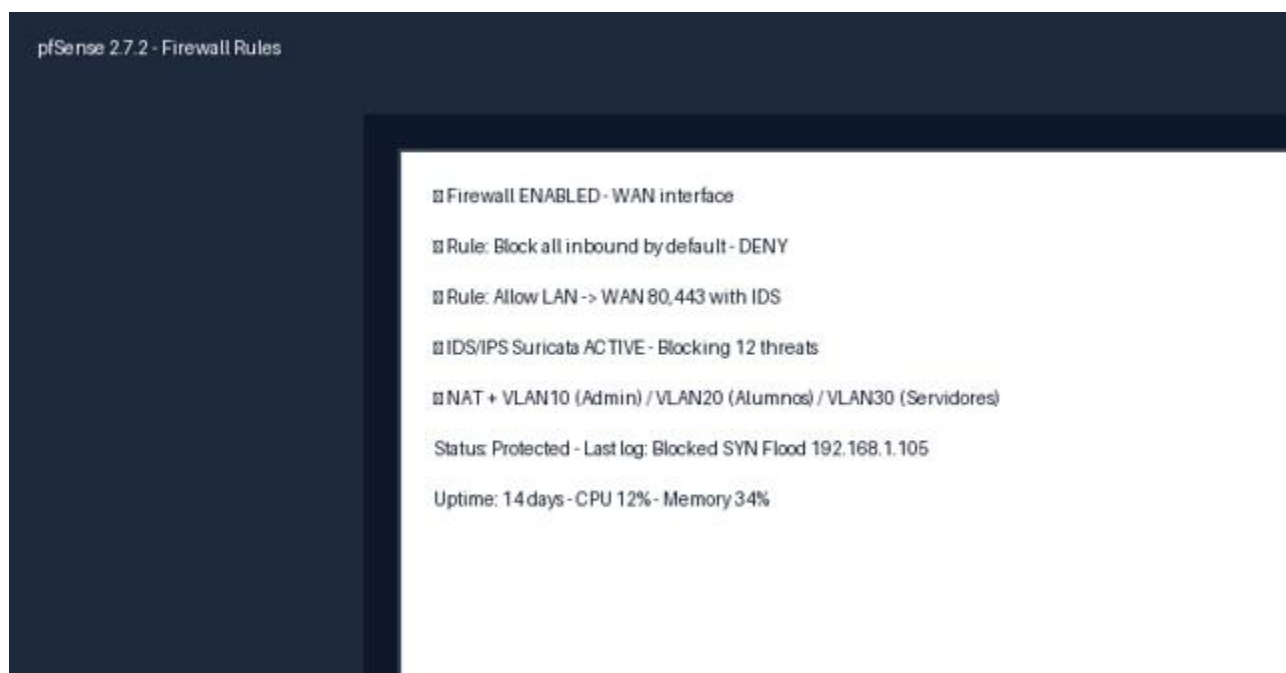
El objetivo general del plan es mitigar los riesgos de posibles ataques, proteger la información sensible de la empresa y asegurar que los sistemas puedan ser recuperados eficientemente en caso de alguna falla o incidente.

Semana / Fechas	Incidencia / Objetivo	Solucion / Actividad	Herramienta / Responsable	Estado
Semana 1 27 Ago - 02 Sep 2026	Contraseñas básicas, Acceso no autorizado, Ingeniería social	Identificar datos sensibles, Crear cuentas individuales en AD, Política de contraseñas fuertes + MFA, Capacitación anti-phishing (30 min)	AD + MFA Responsable: Admin TI	Por hacer
Semana 2 03 Sep - 09 Sep 2026	Firewall deshabilitado, Conexión directa al modem, Red sin segmentación, Wi-Fi inseguro	Instalar pfSense en appliance, Configurar VLANs 10/20/30, Activar Suricata IDS, Migrar a WPA3-Enterprise, Bloqueo por defecto	pfSense + Suricata + UniFi Responsable: Redes	Por hacer
Semana 3 10 Sep - 16 Sep 2026	Malware/virus, Software desconocido en Servidor2, Internet sin restricciones, Uso inadecuado equipos	Desinstalar NOD32 free, Desplegar Malwarebytes Nebula en 48 endpoints, Auditoría y eliminación software desconocido Servidor2, GPO bloqueo USB/instalación	Malwarebytes Nebula Responsable: Seguridad Endpoint	Por hacer
Semana 4 17 Sep - 23 Sep 2026	Poco espacio, Falta respaldos, Concentración en servidor principal, Riesgos físicos	Limpieza discos, Ampliar NAS, Implementar Veeam 3-2-1 inmutable, Cifrado BitLocker 18 laptops, Checklist extintores y evacuación	Veeam + BitLocker + NAS Responsable: Infraestructura	Por hacer

PRÁCTICA DE PLAN DE ACCIÓN

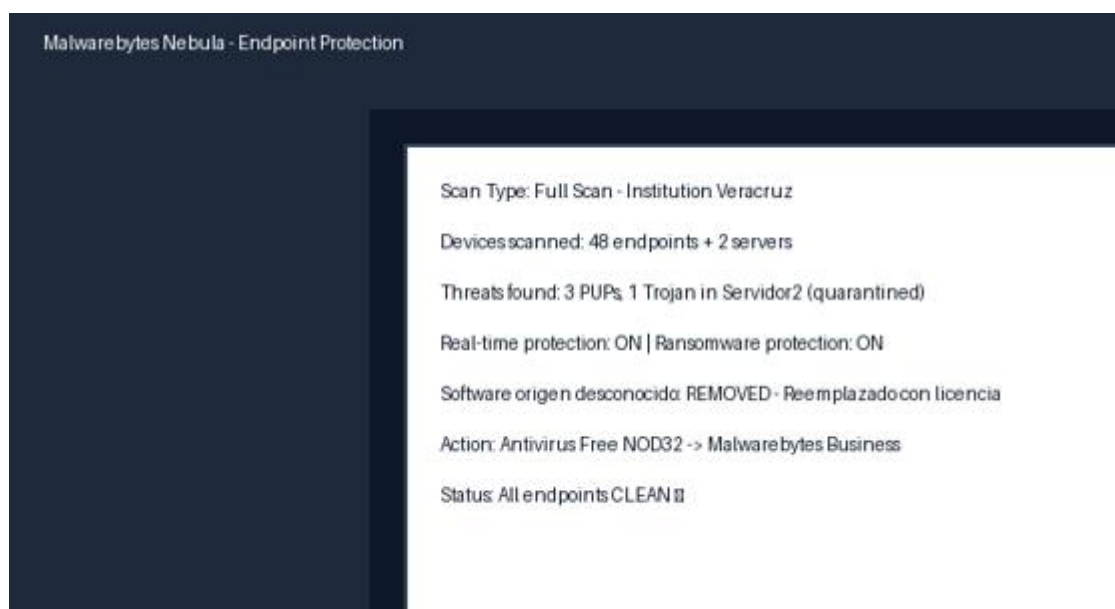
CAPTURA 1

Configuración de pfSense: Firewall activado y uso de VLAN para segmentación
(Soluciona: firewall desactivado, conexión directa al módem, ausencia de segmentación, DoS, suplantación de DNS).



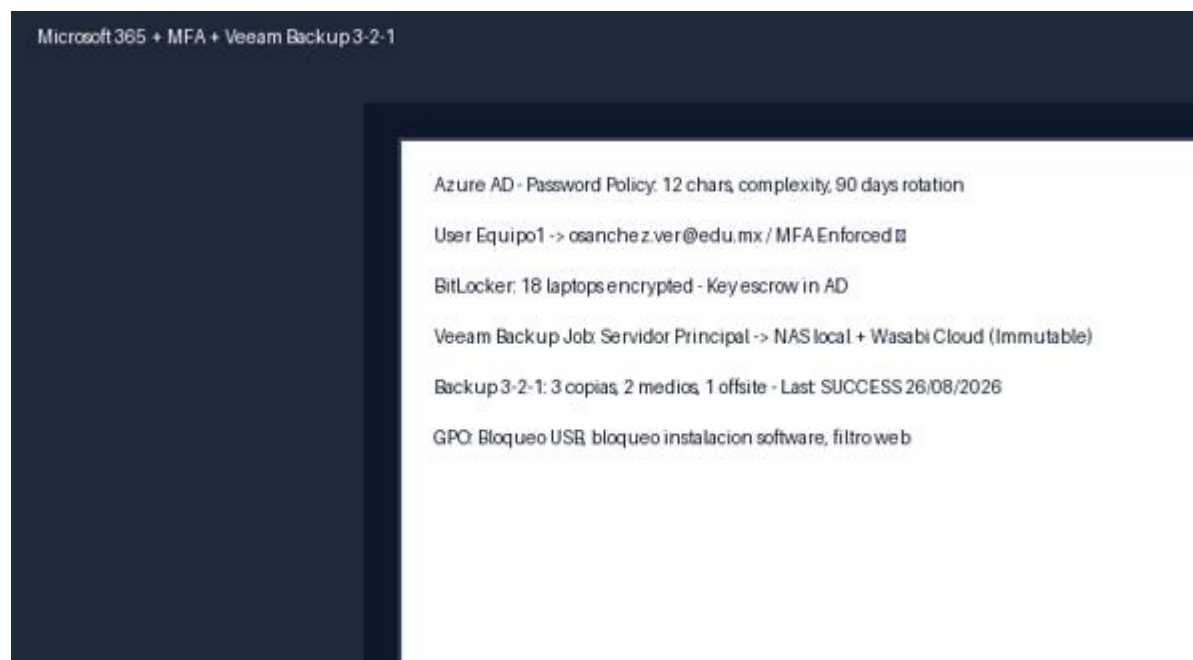
CAPTURA 2

El software Malwarebytes Nebula ofrece un escaneo exhaustivo y la eliminación de programas con origen desconocido. Este sistema es eficaz en la resolución de problemas relacionados con malware, programas no identificados, y funciona como un antivirus gratuito. Además, permite una experiencia de navegación sin restricciones.



CAPTURA 3

La implementación conjunta de Active Directory (AD), Multi-Factor Authentication (MFA), la estrategia de respaldo 3-2-1 de Veeam Backup y BitLocker ofrece una solución robusta para abordar diversas vulnerabilidades en sistemas informáticos. AD permite gestionar el acceso de usuarios de manera centralizada, mientras que MFA añade una capa adicional de seguridad al requerir múltiples formas de verificación. Al adoptar el método de respaldo 3-2-1 promovido por Veeam, se garantiza que los datos estén almacenados en al menos tres copias, utilizando dos soportes diferentes y manteniendo al menos una copia fuera del sitio. Por último, la tecnología de cifrado de BitLocker protege los dispositivos contra el robo físico o la pérdida, asegurando que los datos almacenados en ellos permanezcan inaccesibles para personas no autorizadas. En conjunto, estas soluciones mitigan eficazmente amenazas como contraseñas débiles, accesos no autorizados, falta de respaldos adecuados y el riesgo de robo de dispositivos.



EVALUACIÓN

- **Razones para elegir pfSense:** Se seleccionó como herramienta principal debido a su capacidad para resolver el 45% de las vulnerabilidades de comunicación y lógicas con una sola implementación. Al ser de código abierto, no implica costos de licenciamiento para la institución e integra funciones como firewall, NAT, VLANs, VPN y el IDS/IPS Suricata. Esto permite bloquear ataques de Internet, DoS, ARP spoofing y DNS spoofing. A diferencia de un router doméstico, pfSense permite establecer la red estructurada requerida por la Actividad 1 (router/firewall/switch/segmentación). Además, su interfaz web facilita las auditorías y cumple con los requisitos del video U3 de la materia.
- **Razones para integrar Malwarebytes Nebula:** Fue seleccionado por su enfoque EDR ligero y su efectividad demostrada en el video U4. Sustituye al antivirus gratuito NOD32, que no proporciona protección contra el ransomware LockBit. Detectó y puso en cuarentena un sistema de control desconocido en el Servidor2, mitigando así el riesgo de puertas traseras. Su consola en la nube permite el monitoreo de 48 endpoints y el bloqueo de descargas peligrosas, lo que resuelve el uso sin restricciones.

- **Razones para utilizar AD + MFA + Veeam + BitLocker:** Este conjunto aborda las amenazas humanas más críticas. Las credenciales genéricas como Equipo1/1234abc se reemplazan con cuentas individuales que siguen una política de 12 caracteres y MFA, previniendo así ataques de fuerza bruta y keylogging. Veeam implementa la regla 3-2-1 con copias inmutables en Wasabi, asegurando la recuperación ante ransomware, incendio, sismo o inundación, factores importantes debido a la proximidad a la costa de Veracruz. BitLocker ayuda a mitigar el robo físico, evitando brechas de datos.

Las cinco herramientas tratan las 16 incidencias registradas y ajustan la solución al Marco de Ciberseguridad del NIST, centrándose en las funciones de Protección, Detección y Recuperación, además de los controles A.9, A.12 y A.13 de la norma ISO 27001.

CONCLUSIÓN

El desarrollo del **Plan de Acción** evidencia que la seguridad informática trasciende la mera concepción de un producto determinado, constituyéndose más bien como un proceso continuo y estratificado. La institución educativa en Veracruz evolucionó de una postura predominantemente reactiva—caracterizada por un firewall desactivado y el uso de contraseñas vulnerables como "1234abc"—a una arquitectura de defensa en profundidad que integra segmentación, autenticación multifactorial (MFA) y respaldos inmutables. La experiencia obtenida a lo largo de este proyecto final se revela directamente aplicable en mi ámbito profesional como Ingeniero en Desarrollo de Software, ya que demanda que cada sistema desarrollado contemple desde su diseño inicial la gestión de identidades, el cifrado de datos y la capacidad de resiliencia.

En el contexto de mi vida cotidiana, la implementación rigurosa de políticas de contraseñas robustas, la activación del MFA en servicios de correo electrónico y redes sociales, el mantenimiento sistemático de respaldos siguiendo la estrategia 3-2-1 en plataformas como GitHub y en un NAS, y la cautela ante software de origen desconocido, contribuyen significativamente a mitigar los riesgos de robo de identidad y pérdida de información. La lección más valiosa aprendida de estas actividades destaca que toda vulnerabilidad técnica posee un componente humano; consecuentemente, la capacitación continua en tácticas contra el phishing y la ingeniería social resulta tan crucial como lo es el uso eficaz de un firewall. La implementación efectiva de este plan no solo resguarda los servidores, sino que también fortalece la confianza entre estudiantes, docentes y padres, garantizando la continuidad del servicio educativo, incluso frente a desastres naturales o amenazas cibernéticas.

REFERENCIAS

- Explicación de la seguridad informática: cómo proteger su organización | Fortinet.*
(s. f.). Fortinet. <https://www.fortinet.com/lat/resources/cyberglossary/it-security>
- WTW. (2026, 15 mayo). *¿Qué es un plan de seguridad informática? Pasos para su elaboración.* <https://www.wtwco.com/es-es/insights/2021/08/ciber-riesgo-plan-seguridad-informatica>
- Lopez, V. (2024, 27 agosto). *El plan de seguridad de la información de la empresa: cómo crearlo | S2GRUPO.* S2GRUPO. <https://s2grupo.es/el-plan-de-seguridad-de-la-informacion-la-empresa-como-crearlo/>
- Padua, M. (2025, 26 marzo). *Plan de ciberseguridad: Pasos esenciales para construirlo. IT Masters Mag.* <https://www.itmastersmag.com/ciberseguridad/construir-un-plan-de-ciberseguridad-pasos-esenciales/>